Laboratorio 16.2.6 – Investigación de amenazas de seguridad de red

PARTE 1. Explorar el sitio web de SANS

Paso 1. Localice los recursos de SANS
1. Indique tres recursos disponibles.
Respuesta:
1. Webcasts: seminarios virtuales gratuitos impartidos por expertos sobre temas de ciberseguridad.
2. Newsletters: boletines con noticias, amenazas y vulnerabilidades de seguridad informática.
3. White Papers: documentos técnicos e investigaciones sobre riesgos, ataques y métodos de protección.
Fuente: https://www.sans.org/security-resources

Paso 2. Localice los controles de seguridad críticos de CIS
2. Seleccione uno de los controles y enumere las sugerencias de implementación para este control.
Respuesta:
Control seleccionado: CIS Control 5 – Gestión de cuentas (Account Management).
1. Mantener un inventario actualizado de las cuentas de usuarios, administradores y servicios.
2. Utilizar contraseñas únicas y seguras para cada cuenta.
3. Deshabilitar o eliminar las cuentas inactivas durante 45 días, cuando sea posible.
4. Separar las cuentas administrativas de las cuentas de uso cotidiano.
5. Revisar periódicamente las cuentas de servicio y comprobar que estén autorizadas.
6. Centralizar la administración de cuentas para facilitar su supervisión.
Fuente: https://www.cisecurity.org/controls/cis-controls-navigator

Paso 3. Localice el menú Newsletters
3. Describa brevemente cada uno de los tres boletines disponibles (NewsBites, @RISK y OUCH!).
Respuesta:

- @risk provee un resumen semanal de los nuevos vectores de ataques descubierto
- OUCH!: es una revista para todo el mundo para proveer información para concientizar acerca de la ciberseguridad
- NewsBites: es un resumén ejecutivo publicado semanalmente acerca de los articulos más recientes de ciberseguridad

PARTE 2. Identificar amenazas de seguridad de red recientes

Paso 1. Localice el archivo del boletín @RISK

4. Enumere algunas vulnerabilidades recientes. Explore varios boletines informativos recientes si fuera necesario.
Respuesta:

- CVE-2026-86950: es una vulnerabilidad en CoreGraphics de IOS que fue parcheada en iOS 18.7.11 and iPadOS 18.7.11, iOS 26.7.1 and iPadOS 26.7.1, macOS Sequoia 15.8.1, macOS Tahoe 26.7.1. Consistia en que al procesar un archivo especialmente preparado, un componente del sistema podía escribir datos fuera del espacio de memoria que tenía asignado
- Critical PHP Vulnerability (CVE-2026-109618, CVE-2026-109619): dos fallos criticos en PHP que aprovechan un exploit en el manejo de punteros de php, un atacante podía enviar solicitudes especialmente preparadas a ciertos sistemas que usan PHP y aprovechar errores en el manejo de memoria/estado interno para comprometerlos

Paso 2. Identifique otros sitios sobre amenazas de seguridad
5. Además del sitio de SANS, identifique otros sitios web que proporcionen información sobre amenazas de seguridad recientes.
Respuesta:

- CISA – Known Exploited Vulnerabilities (KEV): catálogo oficial de vulnerabilidades que, según CISA, se están explotando activamente
- The Record, de Recorded Future News: medio especializado que informa sobre incidentes y campañas de ciberataques

6. Enumere algunas de las amenazas de seguridad recientes que se mencionan en estos sitios web.
Respuesta:
En CISA:

- CVE-2026-19868: una vulnerabilidad de autenticación enal servicio SSL VPN de SonicWall SonicOS podría habilitar a usuarios con credenciales válidos para saltarse los controles de inicio de sesión configurados con SAML, también podrían eludir autenticación multifactor
- CVE-2024-27834: Apple iOS, iPadOS, macOS, Safari, tvOS y watchOS 10.5 tienen una vulnerabilidad de autenticación que podría permitirle a atacantes sobrepasar pointer authentication

PARTE 3. Describir con detalle un ataque específico de seguridad de la red

Paso 1. Complete la ficha del ataque seleccionado

Nombre del ataque: PHP2Shell, una cadena de explotación asociada con dos vulnerabilidades del núcleo de PHP: CVE-2026-109618 y CVE-2026-109619.

Tipo de ataque: Ejecución remota de código (RCE) previa a la autenticación. En ciertas condiciones, un atacante podía enviar solicitudes a un servidor expuesto y ejecutar código sin iniciar sesión. También se demostró la posibilidad de leer información sensible de la memoria del proceso PHP.

Fecha de los ataques: Se reportaron intentos de explotación antes de que se publicaran los parches. La vulnerabilidad se hizo pública y PHP publicó actualizaciones el 21 de octubre de 2026; el 29 de octubre, Palo Alto Networks informó de explotación activa contra interfaces de administración PAN-OS expuestas a Internet

Equipos/organizaciones afectadas: Servidores que ejecutaban versiones vulnerables de PHP, incluidos servicios web y aplicaciones construidas con sistemas como WordPress, Drupal y Joomla. Esos sistemas sirvieron como ejemplos de prueba; el fallo estaba en PHP, no en esos productos en particular. También se informó de ataques contra interfaces de administración PAN-OS accesibles desde Internet. No se identificaron públicamente todas las organizaciones víctimas, por lo que no conviene afirmar que una entidad concreta fue comprometida.

Cómo funciona y qué daños causó: Los fallos estaban relacionados con errores de manejo de memoria en PHP al procesar solicitudes y errores graves, como quedarse sin memoria. Ese estado podía dejar referencias inválidas en el proceso; solicitudes posteriores podían aprovecharlas para corromper memoria, revelar datos o ejecutar código. El impacto potencial incluye comprometer el servidor y acceder a la información o recursos disponibles para el proceso PHP. Los reportes técnicos describen explotación y pruebas de concepto, pero no establecen que todos los servidores vulnerables fueran atacados con éxito.

Opciones de mitigación:

- Actualizar PHP de inmediato a una versión corregida: 8.5.12, 8.4.27, 8.3.36 o 8.2.35, o instalar el paquete corregido de la distribución Linux utilizada.
- Si se trata de un producto que incluye PHP —por ejemplo, un dispositivo de red—, instalar la actualización indicada por su fabricante.
- Mientras se actualiza, limitar el acceso público a interfaces de administración y permitirlo solo desde redes de confianza.

Referencias y enlaces de información:

- PHP, avisos y actualizaciones de seguridad: https://www.php.net/
- Wiz Research, análisis técnico de PHP2Shell: https://www.wiz.io/blog/php2shell-php-rce
- Palo Alto Networks Unit 42, informe de amenazas: https://unit42.paloaltonetworks.com/cve-2026-109618-cve-2026-109619/
- SANS, boletín sobre las vulnerabilidades de PHP: https://www.sans.org/newsletters/at-risk/xxvi-41

Paso 2. Presentación

Siga las pautas del instructor para completar la presentación.

PREGUNTAS DE REFLEXIÓN

1. ¿Qué medidas puede tomar para proteger su PC?
- Mantener el sistema operativo, navegador y programas actualizados.
- Usar antivirus y mantener activo el firewall.
- Usar contraseñas largas y únicas; activar la autenticación multifactor cuando esté disponible.
- No abrir enlaces ni archivos adjuntos sospechosos.
- Descargar programas solo de sitios oficiales.
- Hacer copias de seguridad periódicas de los archivos importantes.
- Usar una cuenta sin permisos de administrador para las tareas diarias.

2. ¿Qué medidas pueden seguir las organizaciones para proteger sus recursos?
- Tener un proceso regular para identificar y aplicar actualizaciones de seguridad, priorizando los sistemas vulnerables y expuestos a Internet.
- Limitar el acceso a datos y sistemas según las funciones de cada empleado, con autenticación multifactor.
- Usar firewalls, protección de endpoints y monitoreo de red para detectar actividad sospechosa.
- Capacitar al personal para reconocer phishing y reportar incidentes.
- Mantener copias de seguridad protegidas y probar que se puedan restaurar.
- Contar con un plan de respuesta a incidentes y practicarlo periódicamente.
- Inventariar los equipos, servicios y cuentas para conocer qué necesita protección.